

SIMATS ENGINEERING
ASSESSMENT TOOL II – INDUSTRY PROBLEM
TASK

CO5 – Complete Solution Report

Course: CO5

Name: VISHWA TEJ. V

Reg. No.: 192321124

Q1. Windows Domain Network – NULL Sessions, RPC and Weak Shares

Given Data

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Of those, systems susceptible to SMB-based lateral movement = 60%
- Each compromised system can attempt access to 3 additional systems
- Success probability per attempt = 0.3

Step 1: Initial systems exposed to anonymous enumeration

$$150 \times 0.45 = 67.5 \approx 68 \text{ systems}$$

Approximately 68 systems allow anonymous enumeration.

Step 2: Systems susceptible to SMB lateral movement

$$68 \times 0.60 = 40.8 \approx 41 \text{ systems}$$

Approximately 41 systems are susceptible to SMB-based lateral movement.

Step 3: Expected second-stage spread

$$41 \times 3 = 123 \text{ attempts}$$

$$123 \times 0.3 = 36.9 \approx 37 \text{ successful compromises}$$

Therefore, the expected second-stage spread is approximately 37 systems.

Step 4: Overall estimated compromised systems

$$41 + 37 = 78 \text{ systems}$$

$$78 / 150 \times 100 = 52\%$$

The estimated compromise is approximately 52% of the network, which is below the 70% large-scale compromise threshold.

Conclusion

The network is at serious risk because anonymous enumeration can facilitate lateral movement. Based on the expected-value calculation, the estimated compromise does not exceed 70%. NULL sessions should be prioritized for immediate mitigation because they enable anonymous enumeration; exposed RPC services and weak shares should also be hardened.

Q2. RPC Exposure and Detection

Given Data

- Total systems = 120
- Systems exposing RPC = 70
- Vulnerable RPC systems = 40%
- Successful exploitation probability = 0.5
- Detection probability per attempt = 0.25

Step 1: Number of vulnerable RPC systems

$$70 \times 0.40 = 28 \text{ systems}$$

Step 2: Expected successful compromises

$$28 \times 0.50 = 14 \text{ systems}$$

Step 3: Expected detection alerts

$$28 \times 0.25 = 7 \text{ alerts}$$

Stealth analysis

$$7 / 28 \times 100 = 25\% \text{ of attempts expected to generate alerts}$$

An attacker seeking stealth would face a meaningful chance of detection during repeated exploitation. From a defensive perspective, unnecessary RPC exposure should be reduced, vulnerable systems patched, and IDS monitoring maintained.

Conclusion

The expected number of successfully compromised systems is 14 and the expected number of detection alerts is 7. Direct repeated exploitation is relatively detectable, so the organization should reduce RPC exposure and strengthen monitoring.

Q3. Cloud Linux Server – Service Vulnerabilities and Weak Permissions

Given Data

- Service vulnerability probabilities = 0.30, 0.20, 0.25 and 0.15
- Privilege escalation probability through weak permissions = 0.50

Step 1: Probability that none of the services is vulnerable

$$(1-0.30)(1-0.20)(1-0.25)(1-0.15) \\ 0.70 \times 0.80 \times 0.75 \times 0.85 = 0.357$$

Step 2: Probability that at least one service is vulnerable

$$1 - 0.357 = 0.643 = 64.3\%$$

Step 3: Overall probability of full compromise

$$0.643 \times 0.50 = 0.3215 = 32.15\%$$

Conclusion

There is a 64.3% probability that at least one exposed service is vulnerable. Considering weak permissions as the privilege-escalation stage, the estimated full-compromise probability is 32.15%. Strengthening file permissions reduces privilege-escalation risk but does not remove the initial service-vulnerability risk. Service patching and secure configuration are therefore also required.

Q4. NFS Unauthorized Access and Root Privilege

Given Data

- Subnet 1 unauthorized-access probability = 0.40
- Subnet 2 unauthorized-access probability = 0.30
- Subnet 3 unauthorized-access probability = 0.20
- Privilege escalation to root after NFS access = 0.70

Step 1: Probability that none of the subnets gains unauthorized access

$$(1-0.40)(1-0.30)(1-0.20)$$

$$0.60 \times 0.70 \times 0.80 = 0.336$$

Step 2: Probability that at least one subnet gains access

$$1 - 0.336 = 0.664 = 66.4\%$$

Step 3: Probability of complete compromise

$$0.664 \times 0.70 = 0.4648 = 46.48\%$$

Mitigation evaluation

Restricting NFS access to one required subnet removes two independent access opportunities. The exact new probability depends on which subnet remains authorized. If Subnet 1, 2 or 3 remains, the corresponding unauthorized-access probability is 0.40, 0.30 or 0.20. Thus, where operationally feasible, the lowest-risk required subnet provides the strongest reduction.

Conclusion

The current probability of at least one unauthorized NFS access is 66.4%, and the estimated complete-compromise probability is 46.48%. Restricting NFS access to a single necessary subnet is a strong mitigation when combined with proper access controls and privilege management.

Q5. SQL Injection and Data Exposure

Given Data

- Total database records = 50,000
- Sensitive records = 30%
- Extraction rate = 500 records/second
- Firewall blocks attack after 40 seconds

Step 1: Total records extracted before blocking

$$500 \times 40 = 20,000 \text{ records}$$

Step 2: Percentage of total data compromised

$$20,000 / 50,000 \times 100 = 40\%$$

Step 3: Sensitive records exposed

$$50,000 \times 0.30 = 15,000 \text{ sensitive records in the database}$$

$$20,000 \times 0.30 = 6,000 \text{ sensitive records exposed (assuming the same proportion)}$$

Severity assessment

The attack can extract 20,000 records, representing 40% of the database, including an estimated 6,000 sensitive records. This represents a high-severity data exposure.

Evaluation of the detection mechanism

The application firewall eventually blocks the attack, but 20,000 records can be extracted before blocking. Therefore, detection and blocking alone are not sufficient to protect critical data.

Recommended defensive measures

- Use parameterized queries or prepared statements.
- Apply strong input validation.
- Use least-privilege database accounts.
- Strengthen web-application firewall rules.
- Monitor database activity and security events.
- Perform regular SQL-injection security testing.
- Protect sensitive data with appropriate access controls and encryption.

Conclusion

The existing mechanism provides useful detection and blocking, but it allows substantial data extraction before the attack is stopped. Prevention, rapid detection, least privilege and secure application design should be implemented together.

Overall Conclusion

The five industry scenarios demonstrate how exposed services, weak configurations, inadequate access controls and application vulnerabilities can combine to create significant security risk.

Question	Key Result	Percentage	Risk Assessment
Q1	≈78 compromised systems	52%	Below 70% threshold; serious lateral-movement risk
Q2	14 compromises; 7 alerts	25% alerts/attempts	Exploitation is relatively detectable
Q3	64.3% at least one vulnerable service; 32.15% full compromise	64.3% / 32.15%	Significant cloud-server risk
Q4	66.4% unauthorized access; 46.48%	66.4% / 46.48%	High NFS exposure

	complete compromise		
Q5	20,000 records; ≈6,000 sensitive	40%	High-severity data exposure